KnowOps AI — Bugs Found by Testing

Found 2026-11-08 (full results: `TEST_RESULTS.md`) by black-box probes against the local server, real Gemini embeddings on the real knowledge base, and code reading. "Test" = a `tests/test_suspected_bugs.py` test (xfail until fixed) or the probe that showed it.

Real Postgres, live `/ask`, agent runs, load and the browser were tested afterwards (bugs 21-27). Still untested: see `TEST_RESULTS.md` §8.

Severity: **High** = security or wrong results for users · **Medium** = wrong behaviour in realistic use · **Low** = minor / hardening.

#	Sev	Bug	What it affects	Test
1	**High**	`/cron/reindex` is open to anyone when `CRON_SECRET` is empty (`if settings.cron_secret and …`)	Anyone can trigger re-embedding, spending Gemini quota; one forgotten env var removes the protection silently	`test_cron_reindex_refuses_when_no_secret_is_configured`
2	**High**	Retrieval threshold 0.55 lets out-of-scope text through: "what is 2+2", "Terraform state locking", "AWS S3 lifecycle", a prompt-injection string and 2000xa all returned 3–5 sources (similarity 0.56–0.60)	`/ask` sends unrelated chunks to the model and shows them as citations; the "no answer" safety then depends on the model's prompt alone, not on retrieval. Only pizza/cricket got 0 sources	real probe (needs a `live` test; threshold sweep in plan §5 R5)
3	**Medium**	Closed P1 tickets count as "active P1 incidents" (`status != 'resolved'`)	Dashboard stat `active_p1_incidents` overstates live incidents	`test_closed_p1_ticket_is_not_an_active_incident` (SQL-shape; needs real-DB twin)
4	**Medium**	`/ask` history loads the *first* 8 messages (`ORDER BY id ASC LIMIT 8`)	After 8 messages the model never sees recent turns, so follow-ups like "what about step 2?" lose context in long chats	`test_ask_history_query_prefers_latest_messages`
5	**Medium**	Deleting a runbook from `data/docs/` leaves its document and chunks in the DB	Retired procedures keep being retrieved and cited as current guidance	`test_reindex_removes_documents_whose_file_is_gone`
6	**Medium**	Sections shorter than 80 characters are dropped by the chunker (`MIN_CHUNK_CHARS`)	Short but important runbook sections (one-line commands, contacts) can never be found	`test_short_section_is_not_lost_from_the_index`
7	**Medium**	Login rate limit trusts `X-Forwarded-For` anywhere except Vercel	Off Vercel (local, other hosts) an attacker rotates the header and gets unlimited password guesses	`test_spoofed_forwarded_for_does_not_change_client_ip_off_vercel`
8	**Medium**	CORS: `allow_origins=["*"]` with `allow_credentials=True`; an `https://evil.com` preflight got `access-control-allow-origin: https://evil.com`	Any website's JavaScript may call the API from a visitor's browser. Impact is limited because auth is a bearer token (not a cookie), but it widens attack surface	`test_unknown_origin_is_not_granted_cors_access`
9	**Medium**	Silent insecure defaults: missing env vars fall back to `admin`/`admin` and `jwt_secret="dev-secret"` (D-007)	A deployment missing two env vars is open to anyone who guesses `admin`/`admin` and can forge tokens with the public default secret	no test yet (plan A12)
10	**Low**	Local `.env` still has `GEMINI_CHAT_MODEL=gemini-2.5-flash` (retired); `.env.example` and `config.py` use `gemini-flash-lite-latest`	`/ask` and the agent return 503/404 when run locally with this `.env`; `pytest -m live` chat tests would fail. Config drift, not a code bug	probe: `/ask` -> "404 … gemini-2.5-flash is no longer available"
11	**Low**	JSON `true` accepted for integer fields (`top_k: true` -> 1; `conversation_id: true` -> 1)	Sloppy contract; a client bug sending booleans is silently accepted	`test_boolean_is_rejected_for_top_k`

#	Sev	Bug	What it affects	Test
12	**Low**	Ticket stats omit `closed`, so `total != open + in_progress + resolved`	Dashboard numbers don't add up	read from `get_crm_stats` (plan T9)
13	**Low**	`GET /tickets/{id}` accepts `1.0` (as 1) and ids above int4 return 404, while body ids above int4 return 422	Inconsistent validation between path and body	probe
14	**Low**	401 body echoes the library message (`Invalid token: The specified alg value is not allowed`)	Tells an attacker which JWT check rejected a forged token	probe
15	**Low**	Cron secret compared with `!=` (not constant-time)	Theoretical timing leak of `CRON_SECRET`	code reading
16	**Low**	Typo query "kubernetis rolbak" ranks the DR runbook's rollback above the Kubernetes Rollback section	Typos degrade ranking (top result wrong, correct one maybe in top 5)	real probe
17	**Low**	`crm.create_ticket("…","…","P9")` silently becomes P2 while the API returns 422	The agent path and the API disagree on invalid priorities	code reading (plan T14)
18	**Low**	`PATCH` cannot clear `resolution_notes` (omitted/None keeps the old value)	Wrong notes can't be removed	code reading (plan T6/§2)
19	**Info**	Fixed-window rate limit allows ~2x the limit across a window boundary	Burst of 20 `/ask` in 2 s possible with limit 10	by design; document
20	**Info**	Local `.env` appears to point at the live database (ticket #42 "Phase 14 smoke test" was readable locally)	`pytest -m live` and any local write test write to production data	probe; use a Neon branch
21	**High**	XSS in the console: `formatMarkdown` escapes code fences but not the rest of a model answer; `<img onerror>` in plain text, **`bold`** or inline code runs script (proved in Chrome). The JWT is stored in `localStorage`	A poisoned runbook or a model echoing hostile text can steal the operator's token and act as them	browser test (`static/js/app.js:445`)
22	**Medium**	Follow-up questions lose context: retrieval embeds only the new question, so "what is the first step of that procedure?" was refused even though the conversation was about failover	Multi-turn chat doesn't work for pronoun-style follow-ups	live `/ask`
23	**Medium**	Refusals still return 5 sources (2+2, Terraform, prompt-injection query)	The console shows citation cards under "I don't have enough information", which looks like the answer was sourced (consequence of #2)	live `/ask`
24	**Medium**	Agent with `max_steps=1` reports `total_steps=2` and its resolution is raw reasoning text ("Thought 2 … Action 2: get_ticket(…)")	Operators see internal ReAct text and the step cap is exceeded by one	live agent run
25	**Low**	`/ask` takes 8–9.5 s every time (local -> Neon/Gemini)	Slow answers; prod measured 14 s once	live `/ask`

#	Sev	Bug	What it affects	Test
26	**Low**	DB routes p50 3.6–4.0 s and only ~2.5 req/s at concurrency 10; `/auth/me` (no DB) is capped near 10 req/s with 2 s p50 at concurrency 20	Poor throughput: per-call connection + `register_vector`, and the serialised per-request metrics write	load test
27	**Info**	Rate limits work as designed (`/ask` 10/min, agent 5/min, `Retry-After` present); the window is fixed, see #19	—	concurrent test

Checked and behaving correctly

Wrong password/username -> identical 401; leading-space password rejected; `alg: none` rejected; token in query string

rejected; path traversal on `/static` -> 404; all `/ask`, ticket, agent and metrics bound checks (min–1/max+1, NUL, whitespace-only,

wrong types, malformed JSON, wrong content type) -> clean 422, no 500; cron without/with a wrong secret -> 401; POST to cron -> 405;

in-scope questions (failover, rollback, CrashLoopBackOff, escalation, 502) all ranked the right section first (0.73–0.78).

Suggested fix order

21 (XSS) -> 1 (cron fail-open) -> 2 (threshold/relevance gate) -> 9 and 7 (insecure defaults / header trust) -> 4, 5, 6 (RAG correctness) -> 3, 12 (stats) -> rest.